DOCUMENT DE CADRAGE

Détection & classification des vulnérabilités

Supervision réseau associée (IDS / corrélation de journaux)

Cadre — Bachelor Cybersécurité (NEXA)

ENVIRONNEMENT Lab Docker, 192.168.100.0/24, 9 hôtes | **AUTEUR** Yaël André NEYPATRAIKY

01 CONTEXTE

Ce projet s'inscrit dans une démarche d'audit de sécurité appliquée à un parc d'hôtes simulé. Il couvre l'ensemble de la chaîne qui va de la découverte d'un périmètre réseau inconnu jusqu'à la qualification formelle des risques identifiés, puis à la mise en place d'une supervision permettant de détecter, côté défense, les mêmes activités menées côté offensif. L'objectif pédagogique est de faire le lien entre une approche attaquant et une approche défenseur.

02 PÉRIMÈTRE ET CONTRAINTES

L'ensemble des travaux est mené sur un environnement Docker isolé, constitué de neuf hôtes aux profils hétérogènes (services web, FTP, SSH, sondes de supervision). Aucune action n'est menée en dehors de ce périmètre contrôlé. Les versions de services rencontrées sont volontairement anciennes ou mal configurées, à des fins exclusivement pédagogiques.

03 OBJECTIFS

- Cartographier le périmètre : hôtes actifs, ports, services et versions précises.
- Qualifier chaque service selon un niveau de criticité argumenté.
- Recouper les versions avec les bases CVE et un score de sévérité (CVSS).
- Comparer recherche manuelle et recherche automatisée.
- Vérifier la détection des activités de reconnaissance par la supervision.

04 MÉTHODOLOGIE

La démarche se déroule en trois temps : une découverte réseau progressive (rapide, exhaustive, puis discrète), une analyse combinant recherche manuelle et automatisée pour classer les risques par hôte, et un déploiement de supervision vérifié par corrélation de journaux multi-sources. Les commandes et paramètres précis ne sont pas détaillés ici, par souci de confidentialité méthodologique.

05 DIFFICULTÉS RENCONTRÉES

- Certains scripts de détection automatisée se sont interrompus en erreur sur une partie du périmètre, nécessitant de confirmer manuellement les résultats manquants.
- Une tentative d'authentification automatisée sur un service exposé a échoué après plusieurs minutes sans résultat concluant.
- Un hôte s'est révélé injoignable avec les paramètres de scan par défaut, imposant d'adapter la méthode de détection.

06 LIVRABLES

- Une cartographie complète du périmètre, avec classification de criticité par hôte.
- Un tableau de synthèse des vulnérabilités, recoupées avec les bases CVE et un score de sévérité.
- Une solution de supervision opérationnelle, avec preuve de détection des activités menées en amont.